

PHASE – I: SUMMARY OF CAPEC BASE PAPER – A Design and Development of Web Application Vulnerability Detection Using Graph-Based Modeling Analysis Over CAPEC

This research paper discusses a framework for detecting vulnerabilities in web applications by combining structured cyber threats classification from Common Attack Pattern Enumeration and Classification (CAPEC) with graph-based analysis. The concept behind the paper is motivated by limitations in conventional detection tools like VA scanners and SIEM tools, where the behavioral correlation between events are overlooked, providing limited contextual understanding of attack patterns.

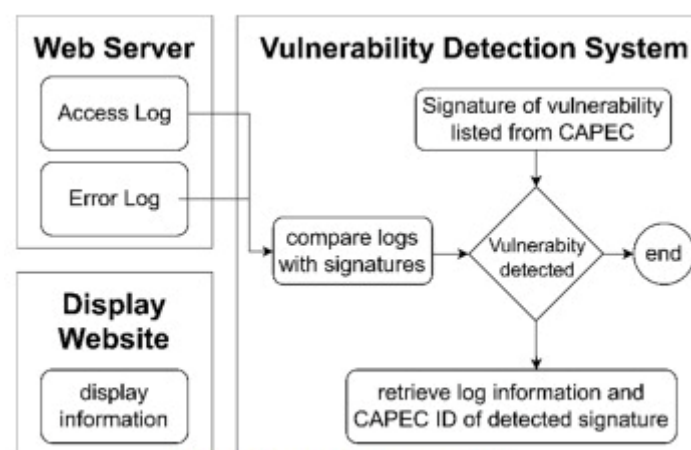


Fig. 1. Proposed system model

The proposed system addresses these gaps by analyzing web server access and error logs and presenting them as a graphical structure using Python libraries such as NetworkX. Log attributes such as timestamp, IP address, HTTP methods, URLs, error messages are modeled as nodes and the relationships as edges. Simultaneously, the known attack patterns from CAPEC are also translated into a graphical form, representing the hierarchical relationships and procedural steps for attacks like SQL Injection, XSS and path traversal.

The subgraph matching algorithm checks whether an attack pattern graph exists within the existing graph formed from the real-time logs. If a match is found, it indicates the presence of a known threat. The graph-based approach hence has better accuracy than static rule-based methods, allowing context-aware correlation, involving complex and multi-step intrusion that might otherwise go unnoticed.

The approach is validated by simulating logs using DirBuster, Faker and PayloadsAllTheThings, incorporating both benign and malicious traffic, resembling real-world attacks. The experiments test the system's performance by scaling both the number of logs and the number of known attack patterns. Results show that detection time scales efficiently with log

volume and is primarily impacted by the number of attack patterns, indicating good scalability. Even with 100,000 log entries, detection time remained within acceptable bounds (~5 seconds), depicting the feasibility of the method for large-scale deployment.

The final output was displayed in a Flask interface, displaying matched attack patterns by their CAPEC IDs and also mitigation strategies and relevant description for each detected attack.

Suggestions for future work is to extend the framework to include threat modeling using MITRE ATT&CK for advanced threat hunting and defense.

We propose to extend the CAPEC-based detection by mapping to real-world CVEs, useful for identifying specific vulnerabilities in hospitals. The CVE linkage helps to assess CVSS score, exploit status, enabling prioritizing based on risk to medical operations or patient records.

PHASE – II: Summary of DT-HP paper – Interplay of Digital Twins and Cyber Deception:

There is not much research going on in the domain which combines Digital Twins and Honey pots with only 15 papers that discuss the synergy of both technologies to be utilized in Cybersecurity, and all of them of low maturity without being peer-reviewed. Hence, this paper explores the area with a comprehensive market desk research and literature survey of the use of combination of both technologies for integrated IT and OT systems. Digital Twin is defined as a virtual instance of a physical system that is continually updated with the latter's performance, maintenance, and health status data throughout the physical system's life cycle." The data flow in the digital twin would be automatic in both directions.

A Honeypot is a security resource whose value lies in being probed, attacked, or compromised. The most relevant feature in the classification of honeypots is the level of interaction, by which it is classified into two: Low-interaction honeypots which provides limited and pre-designed functions with no access to the operating system, and a high-interaction level honeypot which mimics several functions and gives access to the operating system. Similar to the simulation fidelity, the interaction level of honeypots depends on the use case. Usually, low-interaction honeypots are utilized as Intrusion Detection/Prevention Systems (IDS/IPS).

MITRE Engage has provided with a framework for planning and discussing adversary engagement operations, called Engage. The framework refers to a variety of techniques or methods for cyber deception or the utilization of simulated aspects of the environment.

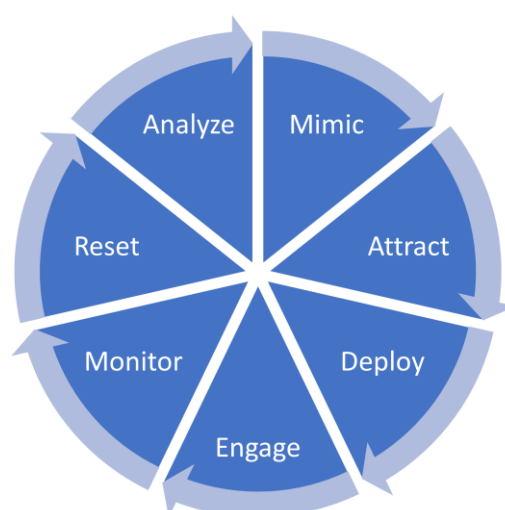
The paper provides with a summary of patterns of intersection between digital twins and honeypots:

Pattern	Brief work description
DT of a system functioning as a HP	- DT-Based Honeypots as a possible application of DT for cybersecurity [13, 14, 16] - Building a DT of an IoT device and using it as a HP. [25] - A DT of a system can perform a function such as a HP [23] - A DT prototypes as HP for Security-By-Isolation (SBI) gateway [11] - A DT behaves as the real system and functions as a HP. Underneath, it is implemented based on Large Language Models (LLM) to provide fake, yet realistic responses to attackers' commands. [24] - Counteracting Information Threats Using HP Systems Based on a Graph of Potential Attacks [36] - IOT honeynet for military deception and indications and warnings [18] - Towards systematic honeytokens fingerprinting [33]
DT of a HP to extend the HP functionality	- Creating a DT of a systems HP for expanded cybersecurity functionality such as anomaly detection and threat intelligence. [28] - Classifying resilience approaches for protecting smart grids against cyber threats [34]
HP as a security solution for a DT	- Discussing HPs as a general security solution for DTs [7]
DT and HP utilized separately	- DT as a general direction for enhancing cyber security. While HPs among the critical defense approaches. In smart grid [38] and manufacturing [27].
HP supports DT	- DT utilized for security attack simulation in SOCs based on the threat intelligence data received from HPs. This makes HP function as a data source for DT-enhanced SOC. [13, 16]
DT: Digital Twins ; HP: Honeypots.	

The paper also provides us with market offerings (tools & technologies) on the intersection between DT and HP.

The paper suggests a new cyber deception framework enabled by digital twin, combining the NIST's cybersecurity framework (NIST CSF): Govern, Identify, Protect, Detect, Respond, and Recover, and the MITRE Engage core: Collect, Detect, Prevent, Direct, Disrupt, Reassure, and Motivate.

The proposed framework:



Mimic: creating realistic replicas;

Attract: attracting attackers with decoys;

Deploy: deploying and orchestrating replicas;

Engage: intercepting and controlling connections with attackers;

Monitor: monitoring and logging attacker activities;

Reset: resetting the network to its original state;

Analyse: analysing and responding to detected activities.

Among the observed approaches for the engagement function are the application of REST API, simple client-based communications API, or reverse proxies. An innovative approach which the paper highlights due to its novelty is the application of Large Language Models (LLMs), particularly ChatGPT, for creating digital twins of systems to operate as honeypots and engaging attackers as a Chatbot.

Summary of SWOT analysis of the proposed framework:

Strengths	Weaknesses
- Improved defender control over attackers. - Increased effort and time for attackers, enabling better response. - Flexible with virtualization for adding components. - Early development opportunities, reducing future costs. - Low implementation costs, leveraging existing tech. - Enhanced security analysis with digital twins. - Risk reduction by containing attackers. - Release of critical resources via digital twins. - Quick reuse and learning with honeypots.	- Challenges in achieving high realism in digital twins. - Need for diverse domain-specific skills. - Management complexity of restoration snapshots. - Logging issues in bandwidth-constrained locations. - Storage and analysis challenges with comprehensive logs. - Unclear replication methods for some components. - Balancing resource utilization and attacker engagement. - Unclear triggers for restoration.
Threats	Opportunities
- Potential for attackers to deduce sensitive info due to high fidelity. - Risk of honeypot detection by attackers. - Resource consumption by excessive attacks. - Limited partner collaboration on digital twin configurations. - Risk of zero-day exploits bypassing engagement functions. - Vulnerabilities in the deception network used as an attack vector. - Risk of inaccurate reporting. - Limited data analytics for advanced threats.	- Research on gradual deployment and optimal resource optimization. - Identifying optimal fidelity levels for components. - Multidisciplinary collaboration among partners to improve industry offerings. - Support for standardization of digital twin technologies.